

ILLUSTRATIVE EXEMPLAR — “what good looks like”

Security Risk Assessment (SW96 / ISO 14971)

Excerpt — connected infusion system

Grounded in (public record): BD Alaris™ Infusion System (510(k) cleared July 2023). Public source: BD press release, news.bd.com (2023-07-21).

Regulatory basis: AAMI SW96:2023; ISO 14971:2019; FDA Premarket Cybersecurity Guidance (2025).

Method

Assets and interfaces are enumerated, threats derived via STRIDE, and each risk scored on **exploitability** and **patient-harm** separately. Controls are selected; residual risk is compared to acceptance criteria and formally accepted.

Risk register (excerpt)

ID	Asset	Threat	Exploit	Harm	Control(s)	Residual
S-01	Wireless link	Spoofing	Med	Med	Mutual-TLS, 802.1X, cert pinning	Low ✓
S-02	Drug library update	Tampering	Low	High	Signed packages, anti-rollback	Low ✓
S-03	EMR interface	Info disclosure	Med	Low	TLS, scoped API, audit logs	Low ✓
S-04	Service/USB	Elevation	Low	High	Port lockdown, signed tools, RBAC	Low ✓
S-05	PCU availability	DoS	Med	Med	Local autonomy, watchdog, safe-state	Med ✓*
S-06	Audit log	Repudiation	Low	Low	Tamper-evident logging to SIEM	Low ✓

Acceptance

All residual risks meet acceptance criteria. * S-05 accepted on the basis that the pump retains local infusion autonomy and enters a safe state independent of the network; compensating controls and monitoring apply. Accepted by Quality + Product Security, with rationale recorded in the risk file.

If a control cannot be implemented

Where a control is infeasible (e.g., per-user authentication on a shared bedside device during a code), the file records the justification, the compensating controls (physical access control, network segmentation, audit logging), the residual risk and its acceptance, and the user-facing limitation in labeling — the approach FDA expects in lieu of the control.